

Data Privacy Policy (Sample)

Company: [Case Study] Global Relocation & Logistics Co.

Version: 1.0 | **Effective Date:** [Insert Date] | **Owner:**

Compliance / GRC

1. Purpose

This policy establishes requirements for the collection, storage, use, and disposal of personal data belonging to clients, employees, and third parties, in alignment with the **Philippine Data Privacy Act of 2012 (RA 10173)** and **ISO/IEC 27001:2022 Annex A.5.34 (Privacy and protection of PII)**.

2. Scope

Applies to all employees, contractors, and third-party partners who collect, process, transmit, or store personal data on behalf of the company, including client shipment records, identification documents, and contact information.

3. Policy Statements

3.1 Data Collection

- Personal data shall be collected only for legitimate, disclosed business purposes (e.g., processing

shipments, relocation coordination, billing).

- Clients must be informed of what data is collected and why, consistent with RA 10173's transparency principle.

3.2 Data Storage & Access

- Personal data shall be stored in access-controlled systems only. Shared drives without permission restrictions are not permitted for documents containing personal data.
- Access shall be granted on a role-based, least-privilege basis (mapped to **NIST CSF PR.AA-05** and **ISO 27001 A.5.15**).

3.3 Third-Party Sharing

- Data shall not be shared with overseas partners or vendors without a signed Data Processing Agreement (DPA) confirming equivalent data protection standards.

3.4 Data Retention & Disposal

- Personal data shall be retained only as long as necessary for the purpose collected, or as required by law, and disposed of securely thereafter (shredding for physical documents, secure deletion for digital records).

3.5 Incident Reporting

- Any suspected loss, unauthorized access, or misdirection of personal data must be reported to the Compliance Officer within 24 hours of discovery, in line with RA 10173's breach notification requirements.

3.6 Training

- All employees handling personal data shall complete data privacy awareness training annually.

4. Enforcement

Violations of this policy may result in corrective action up to and including termination, and may be reportable to the National Privacy Commission where required by law.

5. Related Controls

Control Area	Framework Reference
Access Control	ISO 27001 A.5.15 / NIST CSF PR.AA-05
Data Protection	ISO 27001 A.5.34 / NIST CSF PR.DS-01
Third-Party Risk	ISO 27001 A.5.19 / NIST CSF GV.SC-06
Incident Response	ISO 27001 A.5.24 / NIST CSF RS.MA-01

This is a sample policy created for portfolio/demonstration purposes as part of independent GRC study, modeled on a hypothetical logistics company.